Introduktion til software sikkerhed Del 5

Del 5 – Trusselsmodellering.

Af Martin Edwin Schjødt Nielsen

University College

Trusselsmodellering

Trusselsmodellering handler om at identificere tekniske trusler mod ens system. Misbrugstilfældene, som vi tidligere har identificeret og prioriteret gennem risikoanalysen, er stadig på et højt abstrakt niveau. Man udvælger de vigtigste misbrugstilfælde (dem med højest risikoværdi) og forsøger at kategorisere disse ved hjælp af STRIDE-modellen. Den overordnede fremgangsmåde er at tegne den relevante del af den tekniske arkitektur for hvert misbrugstilfælde og derefter bruge STRIDE-modellen til at identificere trusselskategorier. Dette udføres som en brainstorming-session, hvor hele teamet deltager.

Det er vigtigt at man ikke forsøger at udføre dette for alle misbrugstilfælde, men blot de højst prioriteret misbrugstilfælde, ellers vil processen blive for stor og uoverskuelig.

Arkitektur

I IT er der ikke en klar definition af, hvad arkitektur er. Som udgangspunkt kan man definere det som de store og vigtige dele af ens system. Det er dog vigtigt at understrege, at arkitektur eksisterer på flere abstraktionsniveauer. For eksempel kan man tale om arkitekturen for en enkelt applikation, såsom applikationens lagdeling. Men arkitektur kan også være på systemniveau, hvor der tages udgangspunkt i samspillet mellem flere applikationer. Som udgangspunkt er arkitektur de store, vigtige dele af systemet, som er relevante i en specifik kontekst. I kontekst til trusselsmodellering er udgangspunktet typisk arkitektur på systemniveau, og ikke de enkelte softwareapplikationers interne opbygning.

STRIDE

STRIDE er en model som kategoriserer trusler i 6 kategorier, som vist i Figur 1

STRIDE
Spoofing – Kan man udgive sig for at være en anden.
Tampering – Kan uvedkommende fortage ændringer.
Repudiation – Man kan nægte at havde udført en handling.
Information disclosure – Kan uvedkommende få adgang til information.
Denial of Service – Kan uvedkommende forhindre adgang til systemet.
Elevation of privilege – Kan uvedkommende opnå rettigheder til at udføre operationer i systemet.

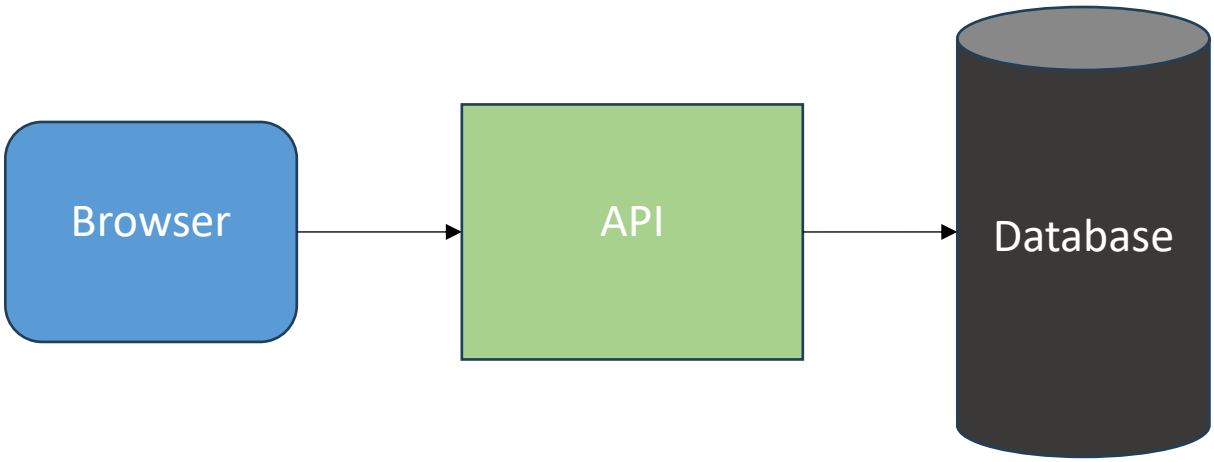
Figur 1 STRIDE trussels kategorier

Kategorierne hjælper med at identificere, hvilken konkret trussel der er imod systemet, når vi laver vores trusselsmodellering. Når en kategori er identificeret som en trussel mod systemet, kan man begynde at lede efter konkrete foranstaltninger mod denne specifikke trussel. For eksempel, hvis jeg søger på Google efter "measures against spoof attack", kommer der en række mulige foranstaltninger frem.

Modellering og arkitektur.

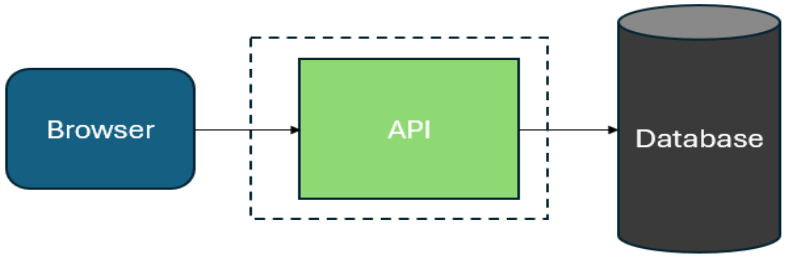
Når vi laver trusselsmodellering, skal vi først tegne den del af vores arkitektur, der er tilknyttet det misbrugstilfælde, vi analyserer. Vi kan tage udgangspunkt i en webapplikation med tilknyttet database,

hvor en aktør interagerer med systemet gennem en browser. Dette kan indledningsvist tegnes som vist i Figur 2



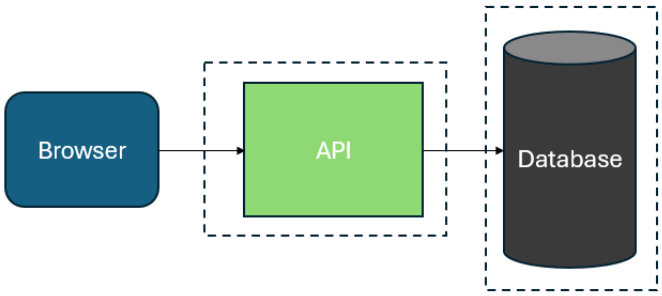
Figur 2 Indledende arkitektur diagram

Nu viser det konceptuelle diagram de store og vigtige dele af systemet i denne kontekst. Den næste del, der kan tilføjes til diagrammet, er tillidsgrænser. Tillidsgrænser viser, hvad enkelte dele selv kontrollerer. For eksempel er alt input fra browseren uden for **API'ets** kontrol, som vist i Figur 3



Figur 3 Tillidsgrænser

Dette betyder, at al data fra browseren er uden for API's kontrol, og at API'et ikke bør stole på data fra browseren. Ligeledes kan vi tilføje en tillidsgrænse mellem API og databasen, som vist i Figur 4.



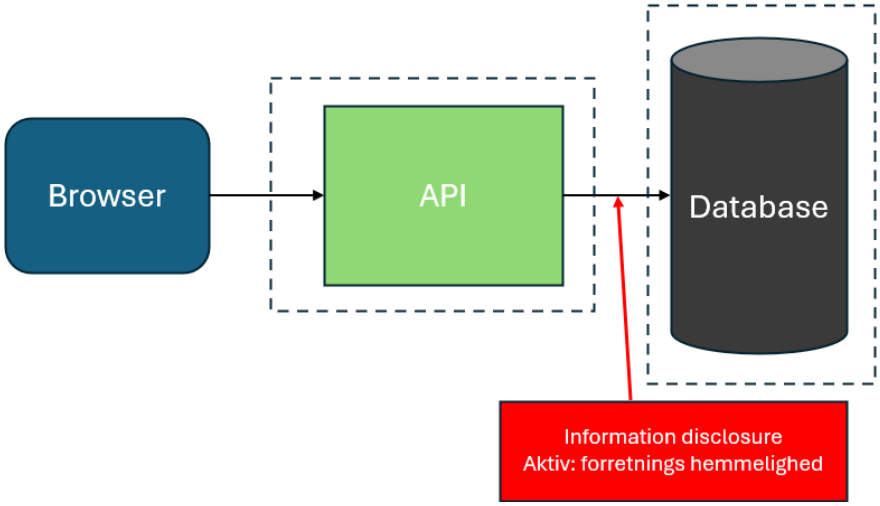
Figur 4 Tillid grænse mellem API og database

Tillidsgrænser viser ofte en logisk eller fysisk afgrænsning mellem de enkelte dele af arkitekturen.

Trusselsmodellering.

Når arkitekturdiagrammet, der er relevant for det enkelte misbrugstilfælde, er på plads, kan den egentlige trusselsmodellering begynde. Her kan man starte med at udvælge de STRIDE-kategorier, der passer til misbrugstilfældet, og derefter begynde at brainstorme ud fra STRIDE-kategorierne og arkitekturdiagrammet.

Et eksempel kan være et misbrugstilfælde med udgangspunkt i afsløringen af en forretningshemmelighed, som systemet har som data (et aktiv). I dette tilfælde er kategorien "Information Disclosure" relevant. På arkitekturdiagrammet identificeres det, at API og databasen udveksler denne data. Dette kan påtegnes diagrammet, som vist i Figur 5.



Figur 5 Identificeret trussel

Herefter kan man udlede et konkret sikkerhedskrav fra den identificerede trussel. For eksempel kan det formuleres som: "Alt kommunikation mellem API og database skal være krypteret med TLS 1.3-protokollen."

Implementeringen af sikkerhedskravene bør prioriteres i overensstemmelse med det sikkerhedsmål, som kravet er udledt fra.

KISS princippet.

Når man laver trusselsmodellering, er det vigtigt at undgå at hænge sig for meget i detaljer. Trusselsmodellering er en iterativ proces, der skal udføres over flere gange. Hvis man fokuserer for meget på detaljer i de første faser, risikerer man at gå i stå.

Trusselsmodellering kan blive uoverskuelig, hvis man ikke prioriterer ud fra risikoanalysen og dermed forsøger at håndtere alle trusler på én gang. Det er altid en god idé at arbejde ud fra KISS-princippet (Keep It Simple, Stupid).